

ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH

TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN

KHOA CÔNG NGHỆ THÔNG TIN



BÁO CÁO ĐỒ ÁN THỰC HÀNH

MÔN HỌC: MÃ HÓA ỨNG DỤNG - LỚP 22 CÔNG NGHỆ TRI THỨC

Vấn đề giao thức IKE trong Ipsec

Sinh viên:

Trần Đoàn Huy Phước – 22127338

Nguyễn Hoàng Khang – 22127178

Nguyễn Khắc Viễn – 22127491

Nguyễn Minh Trực – 22127428

Giảng viên:

TS.Trương Toàn Thịnh

Contents

1	Tổng quan về IP Security (IPSec)	2
1.1	Các kiến thức cơ bản	2
1.1.1	IPSec là gì?	2
1.1.2	Ứng dụng của IPSec	2
1.1.3	Các dịch vụ của IPSec	2
1.1.4	Các chế độ hoạt động của IPSec	2
1.1.5	Các pha trong kiến trúc Ipsec	3
1.2	Chính sách bảo mật trong Ipsec	3
1.2.1	Security Association	3
1.2.2	Security Policy Database	3
1.2.3	Security Association Database	4
1.3	Encapsulating Security Payload trong Ipsec	4
2	Internet Key Exchange (IKE)	5
2.1	Nhắc lại về hệ mã Diffie - Hellman	5
2.2	Các nguyên tắc của giao thức IKE	6
2.3	IKEv1	7
2.4	IKEv2	7
2.4.1	Cấu trúc gói tin thông điệp IKE	8
2.4.2	Quá trình trao đổi thông điệp trong IKEv2 (3 bước chính)	10
2.5	Bộ mã khuyến nghị cho giao thức IKE	16
2.5.1	Virtual Private Networks (RFC 4308)	16
2.5.2	NSA Suite B (RFC 6379)	16
3	Sản phẩm demo của nhóm (có link video demo)	17
4	Tham khảo	18

1 Tổng quan về IP Security (IPSec)

1.1 Các kiến thức cơ bản

1.1.1 IPSec là gì?

- IPSec là một bộ giao thức bảo mật hoạt động ở tầng mạng (tầng 3 trong mô hình OSI), được sử dụng để bảo vệ dữ liệu truyền qua các mạng IP (bao gồm cả IPv4 và IPv6) bao gồm:

- Xác thực (Authentication)
- Bảo mật (Confidentiality)
- Quản lý khóa (Key Management)

1.1.2 Ứng dụng của IPSec

- Bảo vệ VPN (Virtual Private Network): Tạo các kết nối an toàn giữa các chi nhánh trong công ty hoặc giữa người dùng từ xa và mạng nội bộ.
- Tăng cường bảo mật thương mại điện tử: Đảm bảo bảo mật giao dịch/giao tiếp trên Internet.
- Bảo mật hạ tầng mạng: Bảo vệ lưu lượng mạng nội bộ (intranet) và mạng ngoại vi (extranet).

1.1.3 Các dịch vụ của IPSec

- Xác thực (Authentication): Đảm bảo nguồn gốc của dữ liệu và phát hiện mọi thay đổi trái phép.
- Bảo mật (Confidentiality): Mã hóa dữ liệu để ngăn chặn hành vi nghe lén.
- Bảo vệ chống phát lại (Anti-replay): Ngăn chặn các cuộc tấn công lặp lại.
- Quản lý khóa (Key Management): Hỗ trợ trao đổi khóa an toàn giữa các thiết bị.

1.1.4 Các chế độ hoạt động của IPSec

- Chế độ vận chuyển (Transport Mode): Bảo vệ payload của gói tin IP mà không mã hóa tiêu đề (header).
- Chế độ đường hầm (Tunnel Mode): Bảo vệ toàn bộ gói tin IP, bao gồm tiêu đề và payload.

1.1.5 Các pha trong kiến trúc Ipsec

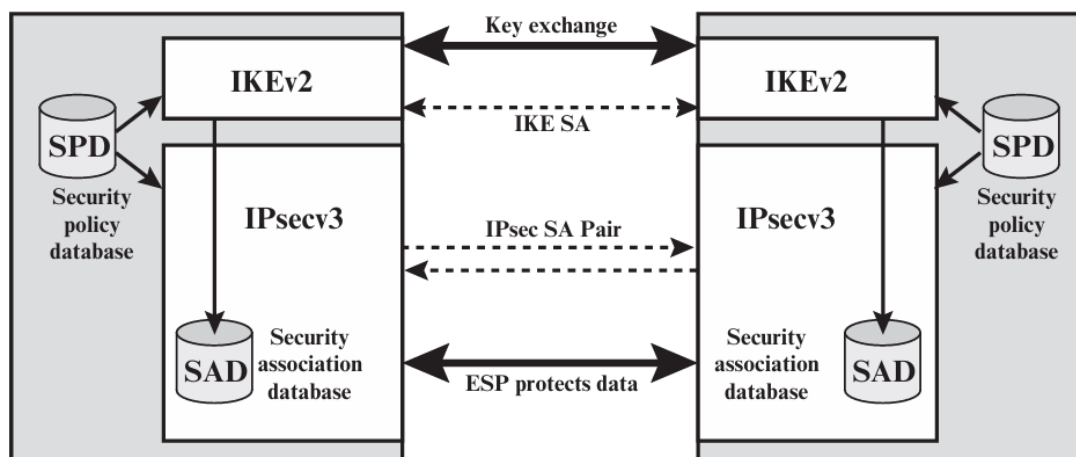


Figure 1: Kiến trúc Ipsec

- Mỗi máy kiểm tra Security Policy Database (SPD) để quyết định xem gói tin cần được bảo vệ bằng IPsec hay không.
- Nếu cần bảo vệ, hai máy thực hiện quá trình trao đổi IKEv2, đàm phán thuật toán mã hóa/xác thực và sinh khóa, tạo ra IKE SA.
- Thông tin về SA (khóa, thuật toán được chọn) được lưu vào Security Association Database (SAD) ở cả hai bên.
- Khi gửi hoặc nhận gói tin, IPsecv3 (thường là ESP) sử dụng SA từ SAD để mã hóa và/hoặc xác thực gói tin.
- Dữ liệu đã được bảo vệ sẽ truyền qua mạng giữa hai máy một cách an toàn.

1.2 Chính sách bảo mật trong Ipsec

1.2.1 Security Association

- SA (tạm dịch: Liên kết bảo mật) là khái niệm quan trọng trong giao thức IPSec, liên quan cách xác định bảo vệ dữ liệu (mã hóa, xác thực) khi giao tiếp 2 bên.
- SA có quan hệ một chiều quy định cách dịch vụ bảo mật (Mã hóa hoặc chứng thực) mà bên gửi hoặc bên nhận muốn thực hiện.
- Nếu cần một mối quan hệ ngang hàng để trao đổi bảo mật hai chiều, thì cần thiết lập hai SA.

1.2.2 Security Policy Database

- SPD (tạm dịch: Cơ sở dữ liệu chính sách bảo mật) là cơ sở dữ liệu lưu các quy ước về liên kết bảo mật (SA). Bao gồm các tham số là:

- **Hành động (Actions)** (quyết định Mã hóa / Xác thực bằng Ipsec, quyết định bỏ qua Ipsec, quyết định loại bỏ gói tin).

- **Tham số bảo mật (Security Parameters)** bao gồm thuật toán mã hóa / xác thực sẽ dùng tới, thời gian sống của SA.
- **Bộ chọn (Selectors)** bao gồm Địa chỉ IP nguồn / đích, Cổng nguồn/đích (TCP / UDP), Giao thức (IPv4, IPv6, ESP...).

- SPD hoạt động như một "bộ luật" hướng dẫn cách xử lý các gói tin khi đi qua thiết bị hỗ trợ giao thức IPsec.

1.2.3 Security Association Database

- SAD (tạm dịch: Cơ sở dữ liệu liên kết bảo mật) là một cơ sở dữ liệu trong IPsec dùng để lưu trữ thông tin chi tiết về các SA đã được thiết lập. SAD cung cấp các thông tin cần thiết để IPsec thực hiện mã hóa, xác thực, và bảo vệ gói tin. Bao gồm các tham số quan trọng nhất là:

- **Security Parameter Index (SPI)** là một số định danh duy nhất (32-bit) dùng để xác định SA.
- **Cửa sổ chống gói tin lặp lại (Anti-Replay Window)** dùng để xác định xem một gói tin AH hoặc ESP nhận vào có bị lặp lại (replay) hay không..
- **AH Information (Thông tin về Authentication Header)** lưu trữ thông tin cho cơ chế xác thực AH (Thuật toán xác thực, khóa dùng cho xác thực, thời gian sống (lifetime) của khóa)
- **ESP Information (Thông tin về Encapsulating Security Payload)** Lưu trữ thông tin cho cơ chế mã hóa và xác thực ESP (Thuật toán mã hóa và xác thực, khóa dùng cho mã hóa / xác thực, thời gian sống (lifetime) của khóa)

- Các thành phần này giúp SAD cung cấp thông tin cần thiết để xử lý các gói tin bảo mật trong giao thức IPsec, hỗ trợ thực thi các "luật" đã được chỉ định trong SPD. Đảm bảo an toàn và chính xác trong quá trình truyền dữ liệu.

1.3 Encapsulating Security Payload trong Ipsec

- Giao thức ESP (Encapsulating Security Payload) trong IPsec được thiết kế để cung cấp nhiều dịch vụ bảo mật cho lưu lượng IP, bao gồm

- Bảo mật dữ liệu (confidentiality)
- Xác thực nguồn dữ liệu (data origin authentication)
- Đảm bảo toàn vẹn dữ liệu (connectionless integrity)
- Chống tấn công phát lại (anti-replay)

- Những tính năng này giúp ESP trở thành một giải pháp bảo mật toàn diện hơn so với AH (Authentication Header), vốn chỉ cung cấp xác thực và toàn vẹn dữ liệu mà không hỗ trợ mã hóa.

2 Internet Key Exchange (IKE)

- Giao thức IKE (Internet Key Exchange) là một giao thức trong kiến trúc IPsec, dùng để thiết lập và quản lý các liên kết bảo mật (Security Associations - SAs) giữa hai thiết bị mạng. Nó đảm nhiệm việc tự động hóa quá trình tạo khóa, xác thực các bên giao tiếp và thương lượng các thông số bảo mật, giúp đảm bảo một kênh truyền dữ liệu an toàn.

2.1 Nhắc lại về hệ mã Diffie - Hellman

- Nhắc lại, phần tử g trong nhóm Z_p^* với p là số nguyên tố lớn được gọi là phần tử sinh nếu nó thỏa tính chất sau:

$$\forall x \in [1, p-2], g^x \not\equiv 1 \pmod{p}$$

- Cho một số nguyên tố p lớn và một số nguyên dương g là phần tử sinh trong nhóm Z_p^* . Alice và Bob thực hiện giao thức trao đổi khóa Diffie Hellman lần lượt theo các bước như sau:

- 1. Alice chọn ngẫu nhiên một số nguyên dương bí mật là $a \in Z_p^*$ và gửi cho Bob giá trị công khai $A = g^a \pmod{p}$.
- 2. Bob chọn ngẫu nhiên một số nguyên dương bí mật là $b \in Z_p^*$ và gửi cho Alice giá trị công khai $B = g^b \pmod{p}$.
- 3. Với giá trị bí mật a của Alice và giá trị công khai $B = g^b \pmod{p}$ của Bob, Alice thu được khóa bí mật chung là

$$K = B^a \equiv (g^b)^a \equiv g^{ab} \pmod{p}.$$

- 4. Tương tự, Bob cũng thu được khóa bí mật chung là $K = A^b \equiv (g^a)^b \equiv g^{ab} \pmod{p}$.

- Tuy nhiên, có một số điểm yếu của Diffie-Hellman là:

- Hệ mã không cung cấp bất kỳ thông tin nào về danh tính của các bên tham gia.
- Dễ bị tấn công man-in-the-middle, trong đó một bên thứ ba C mạo danh B khi giao tiếp với A và mạo danh A khi giao tiếp với B. Cả A và B đều kết thúc quá trình đàm phán khóa với C, vậy là C có thể nghe lén và chuyển tiếp dữ liệu. Cuộc tấn công man-in-the-middle diễn ra như sau:

1. B gửi khóa công khai của mình là Y_B trong một tin nhắn gửi tới A.
2. Kẻ tấn công C chặn tin nhắn này. C lưu khóa công khai của B và gửi một tin nhắn tới A với ID người dùng của B nhưng là khóa công khai Y_E của E. Vậy A đã nhận ID của B và khóa Y_C của C mà lại lầm tưởng đó là Y_B của B. Tương tự, C gửi tin nhắn tới B với khóa công khai của C, B lại lầm tưởng khóa công khai này đến từ A.

3. (a) B nghĩ mình đang trao đổi với A, nên dùng khóa công khai Y_C B tính toán khóa bí mật:

$$K_1 = Y_C^{X_B} \pmod{p}$$

→ B dùng khóa riêng của B và khóa công khai của C.

- (b) A cũng bị lừa bởi kẻ tấn công C, nên dùng Y_C để trao đổi khóa. A tính toán khóa bí mật:

$$K_2 = Y_C^{X_A} \pmod{p}$$

→ A dùng khóa riêng của A và khóa công khai của C.

- (c) C (kẻ tấn công) biết cả hai khóa riêng của mình là X_C , nên:

- Tính toán được K_1 :

$$K_1 = Y_B^{X_C} \pmod{p}$$

→ C Dùng khóa công khai của B và khóa riêng của E.

- Tính toán được K_2 :

$$K_2 = Y_A^{X_C} \pmod{p}$$

→ C dùng khóa công khai của A và khóa riêng của E.

4. Từ thời điểm này, C có thể chuyển tiếp tin nhắn giữa A và B và ngược lại, bằng cách thay đổi mã hóa trên đường truyền sao cho cả A và B đều không biết rằng họ đang chia sẻ thông tin với E.

- Dễ bị tấn công tắc nghẽn (clogging attack): Kẻ tấn công lợi dụng tính chất hệ mã này tính toán rất tốn kém để yêu cầu số lượng lớn khóa. Nạn nhân tiêu tốn đáng kể tài nguyên tính toán để thực hiện lũy thừa modulo một cách vô ích.

- Việc xác định khóa trong IKE được thiết kế để giữ lại các ưu điểm của và khắc phục các điểm yếu của Diffie-Hellman.

2.2 Các nguyên tắc của giao thức IKE

- Sử dụng thuật toán Diffie-Hellman: IKE sử dụng một phiên bản cải tiến của thuật toán Diffie-Hellman để cho phép hai máy tính thỏa thuận về một khóa bí mật chung một cách an toàn thông qua một kênh không an toàn.

- Thỏa thuận về thuật toán DH nào sẽ được sử dụng, kèm theo là các tham số: Trước khi thực hiện trao đổi DH, hai bên phải thỏa thuận về thuật toán DH khác nhau (Các nhóm trong đường cong Elliptic hoặc các nhóm trong DH nguyên gốc (Modulo các số nguyên tố)) và các tham số toàn cục như một số nguyên tố lớn p và một số nguyên g là phần tử sinh trong nhóm Z_p^*

- Sử dụng nonces: Để chống lại các cuộc tấn công lặp lại, IKE sử dụng nonces, là các số giả ngẫu

nhien được tạo cục bộ và trao đổi giữa hai bên. Các nonces này được bao gồm trong các tính toán khóa, đảm bảo rằng mỗi lần trao đổi khóa sẽ tạo ra một bộ khóa phiên mới và duy nhất.

- Sử dụng kĩ thuật cookies để ngăn việc tấn công tắc nghẽn (Clogging Attack).
- Phải xác thực quá trình trao đổi khóa DH để ngăn chặn tấn công man in the middle: Có thể sử dụng các phương pháp xác thực là chữ ký số, hệ mã đối xứng, hệ mã bất đối xứng.

2.3 IKEv1

- Là phiên bản đầu tiên của giao thức IKE (Internet Key Exchange), IKEv1 sử dụng 2 giao thức ISAKMP (Internet Security Association and Key Management Protocol) và Oakley để xác thực và tạo khóa.

- Giao thức IKEv1 khi được thực thi bao gồm các bước sau:

- Bước 1: Xác thực và thỏa thuận các thông số bảo mật SA IKE/SA ISAKMP nhằm thiết lập được một kênh truyền tin bảo mật. Số lượng message cần để thiết lập được các thông số này sẽ phụ thuộc vào chế độ được chọn (Main hay Agressive). Các thông số bắt buộc phải thiết lập được ở bước này bao gồm:
 - Thuật toán mã hóa: DES, 3DES, AES
 - Thuật toán hash: MD5, SHA
 - Phương pháp xác thực: Preshare-key, RSA
 - Nhóm khóa Diffie-Hellman
- Bước 2: Sau khi đã thiết lập được kênh truyền tin bảo mật ở bước 1, giao thức tiếp tục thỏa thuận các thông số bảo mật SA IPsec phù hợp nhằm chọn chế độ đóng gói dữ liệu và chế độ hoạt động. Các thông số bắt buộc phải thiết lập được ở bước này bao gồm:
 - Giao thức IPSec: ESP hoặc AH.
 - IPSec mode: Tunnel hoặc transport.
 - IPSec SA lifetime: dùng để thỏa thuận lại SA IPSec sau một khoảng thời gian mặc định hoặc được chỉ định.
 - Trao đổi khóa Diffie-Hellman.

2.4 IKEv2

- IKEv2 là phiên bản cải tiến của giao thức IKE, được thiết kế để khắc phục các hạn chế và phức tạp của IKEv1. Trong khi IKEv1 dựa trên hai giao thức ISAKMP và Oakley để thực hiện xác thực và trao đổi khóa, IKEv2 đã hợp nhất các chức năng này thành một giao thức đơn giản và hiệu quả hơn.

2.4.1 Cấu trúc gói tin thông điệp IKE

- Thông điệp IKE bản chất là gói tin nhị phân, có cấu trúc gồm 2 phần chính:

- Header: Là phần tiêu đề của gói tin, chứa thông tin bao quát chung của gói tin đó.

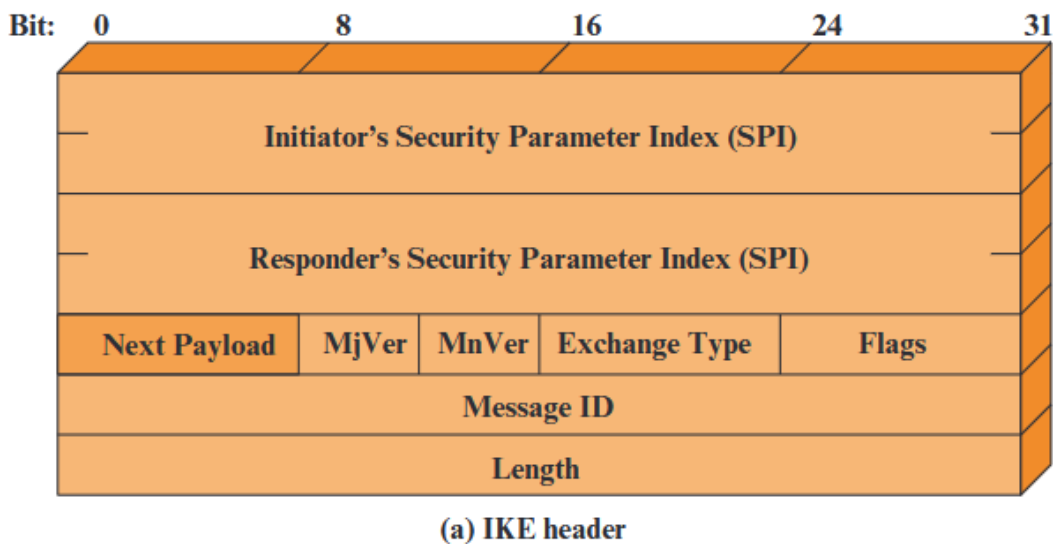


Figure 2: Cấu trúc phần tiêu đề của thông điệp IKE

- Các payload, phần dữ liệu chính:

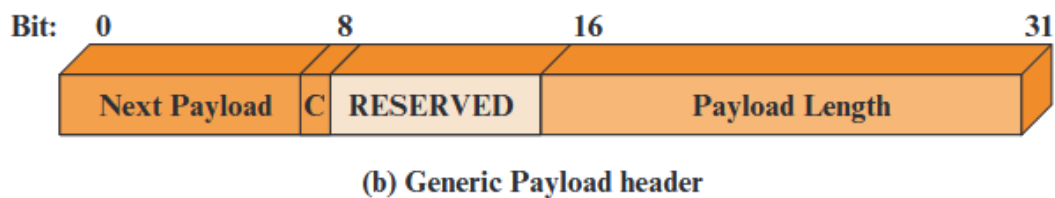


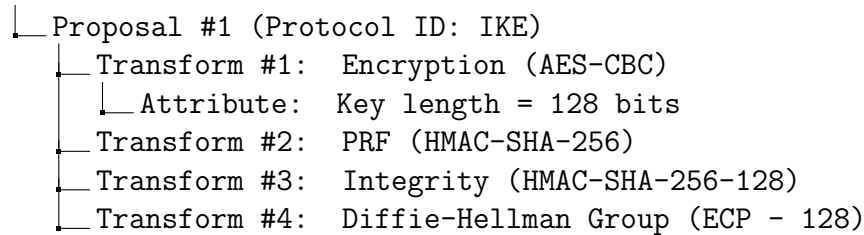
Figure 3: Cấu trúc phần tiêu đề của IKE payload

- * Là các phần dữ liệu chứa thông tin chi tiết cần trao đổi trong phiên giao tiếp IKE.
- * Bao gồm phần Generic Header đi trước để thông báo thông tin tổng quát về Payload đó, tiếp sau là Payload.
- * Mỗi payload đều có một trường Next Payload để liên kết payload tiếp theo (hoặc giá trị 0 nếu là payload cuối cùng).

– Những loại payload quan trọng:

* Security Association (SA): Là payload đầu tiên trong quá trình thiết lập phiên IKE, Dùng để thỏa thuận các tham số bảo mật như thuật toán mã hóa, hàm băm, và nhóm Diffie-Hellman. Payload này có cấu trúc phân cấp phức tạp, gồm các thành phần nhỏ hơn:

- Proposal là đề xuất cụ thể của một bên (Initiator hoặc Responder) về việc thiết lập các thông số bảo mật cho phiên giao tiếp. Một SA payload có thể chứa một hoặc nhiều Proposal khác nhau. Mỗi Proposal gồm:
 - **Proposal number:** Số thứ tự để định danh mỗi đề xuất.
 - **Protocol ID:** Xác định giao thức liên quan đến Proposal (ví dụ: AH, ESP, hoặc IKE).
 - **Number of transforms:** Cho biết có bao nhiêu transform đi kèm trong proposal này.
 - **Transform Substructures:** Là danh sách các transform (các thuật toán mã hóa, xác thực...) mà bên gửi muốn đề xuất sử dụng.
- Trong mỗi Proposal có thể chứa nhiều Transform. Transform là các thuật toán hay các cơ chế mã hóa, xác thực, tạo khóa,... dùng để thiết lập SA. Ví dụ về các loại Transform phổ biến:
 - Thuật toán mã hóa: AES-CBC, AES-GCM, 3DES, v.v.
 - Hàm xác thực (Integrity): HMAC-SHA256, HMAC-MD5, v.v.
 - Nhóm Diffie-Hellman: MODP-2048, ECP-256, v.v.
- Mỗi Transform có thể kèm theo các Attribute để mô tả chi tiết hơn về Transform đó, như độ dài khóa, phương thức hoạt động cụ thể,... Ví dụ về Attribute:
 - **Key length:** Với AES-128, Attribute sẽ là độ dài khóa = 128 bits.
 - **PRF algorithm:** Chỉ định hàm giả ngẫu nhiên (PRF) cụ thể (HMAC-SHA256).
 - **Mode of operation:** Với AES thì Attribute có thể là CBC mode, GCM mode,...
 - Đối với chuẩn RFC 7296, phần attribute chỉ để bổ sung thông tin về độ dài của khóa mà thôi.
- Ví dụ Initiator đề xuất 1 bộ mã gồm các thuật toán: AES - CBC 128 bit key cho mã hóa, HMAC-SHA-256 cho hàm sinh số giả ngẫu nhiên, HMAC-SHA-256-128 cho xác thực, ECP 256 bit cho tính toán khóa Diffie Hellman, thì cây phân cấp biểu diễn SA payload (RFC 7296) sẽ như thế này:
SA Payload



- * Key Exchange (KE): Chứa khóa công khai Diffie-Hellman để 2 bên tính toán khóa bí mật chung.
 - * Nonce (Ni/Nr): Chứa số ngẫu nhiên được phát sinh từ mỗi bên. Đảm bảo tính mới mỗi phiên giao tiếp và tránh tấn công phát lại.
 - * Authentication (AUTH): Chứa thông tin xác thực, như chữ ký số hoặc giá trị hash dựa trên khóa chia sẻ trước (PSK). Dùng để xác minh danh tính của mỗi bên tham gia.
 - * Identification: Chứa thông tin định danh của máy. Thông tin có thể định danh có thể là chuỗi Ipv4, Ipv6, chuỗi tên miền,..
 - * Encrypting: Chứa bản mã các payloads khác gộp lại và chuỗi IV để giải mã.
- Ngoài ra còn nhiều kiểu payloads khác như: N, D, CP cho pha trao đổi Informational, hoặc Tsi Tsr để xác định lưu lượng giao tiếp được bảo vệ bằng Ipsec.

2.4.2 Quá trình trao đổi thông điệp trong IKEv2 (3 bước chính)

HDR = IKE header	SK {...} = MAC and encrypt
SAX1 = offered and chosen algorithms, DH group	AUTH = Authentication
KEx = Diffie-Hellman public key	SAX2 = algorithms, parameters for IPsec SA
Nx = nonces	TSx = traffic selectors for IPsec SA
CERTREQ = Certificate request	N = Notify
IDx = identity	D = Delete
CERT = certificate	CP = Configuration

Figure 4: Chú thích các gói tin, trong đó gói tin trong ô vuông □ là tự chọn, không bắt buộc gửi.

- Bước 1.1: Trao đổi IKE_SA_INIT

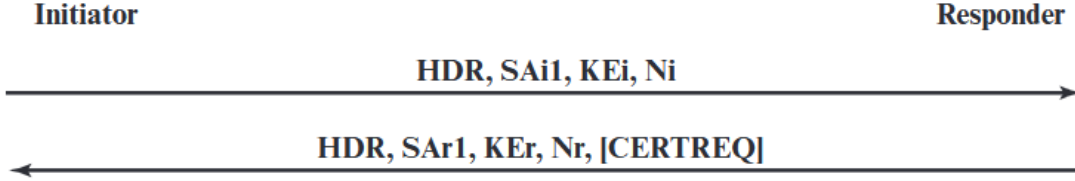


Figure 5: IKE SA INIT

- Mục đích: Thiết lập quan hệ bảo mật giữa hai máy.
- Quá trình:
 - * Thỏa thuận thuật toán mã hóa, xác thức, chứng chỉ số nào sẽ được chọn.
 - Initiator sẽ gửi cho Responder đề xuất về các bộ mã cần sử dụng thông qua SA payload.
 - Responder sẽ căn cứ khả năng hỗ trợ của mình được bao nhiêu bộ mã thì sẽ gửi về Initiator bộ mã mà bên Responder chọn.
 - * Trao đổi khóa Diffie-Hellman để tạo khóa bí mật chung (DH_{shared}) thông qua gói tin KE.
 - * Trao đổi Nonce (một số ngẫu nhiên) để đảm bảo tính mới của phiên giao tiếp, tránh bị tấn công lặp lại (N_i và N_r).
 - * Trao đổi SPI (cũng là một số ngẫu nhiên, là số định danh cho gói tin IKE message). Dùng để tạo nên chuỗi khóa từ khóa mầm Skeyseed (SPI_i và SPI_R).
 - * Dùng hàm giả ngẫu nhiên với đầu vào là các giá trị Nonce, khóa chung Diffie-Hellman ở 2 máy để tạo ra một giá trị SKEYSEED
 - * Giá trị SKEYSEED được tính bằng hàm giả ngẫu nhiên PRF (Pseudo-Random Function):

$$SKEYSEED = PRF(N_i \parallel N_r, DH_{shared})$$

Trong IKEv2, hàm PRF thường là HMAC-SHA256:

$$SKEYSEED = HMAC - SHA256(data = N_i \parallel N_r, key = DH_{shared})$$

Với: $\parallel$ là phép ghép nối chuỗi bit.

- * Từ giá trị Skeyseed, ta cho vào hàm Prf+ (Hàm sinh số giả ngẫu nhiên bổ sung) để sinh ra các chuỗi khóa. Việc tính khóa này được thực hiện riêng trên 2 máy để đảm bảo bí mật, với công thức:

$$KEYMAT = PRF^+(K, S) = T_1 \parallel T_2 \parallel T_3 \parallel \dots$$

Trong đó:

$$\begin{aligned} T_1 &= PRF(K, S \parallel 0x01) \\ T_2 &= PRF(K, T_1 \parallel S \parallel 0x02) \\ T_3 &= PRF(K, T_2 \parallel S \parallel 0x03) \\ &\dots \end{aligned}$$

với: $K = SKEYSEED$, $S = N_i \parallel N_r \parallel SPI_i \parallel SPI_r$. Các giá trị 0x01, 0x02, 0x03, ... là các byte được thêm vào cuối để đảm bảo tính duy nhất mỗi vòng lặp.

- * Cách tách khóa từ chùm khóa *KEYMAT*: Chuỗi khóa được tạo ra từ hàm mở rộng PRF+ (*KEYMAT*) là một chuỗi dữ liệu dài. Ta chỉ đơn giản cắt chuỗi thành các khóa con theo kích thước khóa trong các bộ mã được thỏa thuận ban đầu giữa Initiator và Responder.
- * Mỗi bộ mã sẽ quy định rõ kích thước từng khóa cần thiết như sau:
 - Khóa mã hóa: VD: AES-CBC 128-bit (16 byte) hoặc AES-CBC 256-bit (32 byte).
 - Khóa xác thực: VD: HMAC-SHA-256-128 (16 byte), HMAC-SHA-256 (32 byte),...
 - Khóa SK_d : Thường có kích thước bằng độ dài đầu ra của hàm PRF (ví dụ: 32 byte đối với HMAC-SHA256).
- * Vậy sau khi cắt thành các khóa con từ chùm khóa *KEYMAT* thì ta có các khóa như sau: SK_d (dành cho việc sinh khóa của các SA con sau này), SK_{e_i} và SK_{e_r} (Khóa mã hóa, lần lượt là khóa từ chiều Initiator tới Responder và chiều Responder tới Initiator), SK_{a_i} và SK_{a_r} (Khóa xác thực, lần lượt là khóa từ chiều Initiator tới Responder và chiều Responder tới Initiator)
- Kết quả: Tạo IKE Security Association (IKE SA), hình thành chính sách bảo mật giữa hai máy.

- Bước 1.2: Trao đổi IKE_AUTH

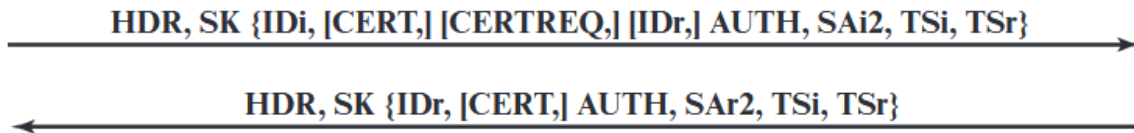


Figure 6: IKE SA AUTH

- Mục đích: Vì bước 1.1 hai bên vẫn chưa tin cậy lẫn nhau. Nên bước này sẽ xác thực danh tính hai bên. Có rất nhiều cách xác thực danh tính như dùng chữ ký số, mã hóa đối xứng, mã hóa bất đối xứng. Ở đây **trình bày quá trình 2 bên dùng MAC để xác thực và kiểm tra toàn vẹn dữ liệu**

- Quá trình:

- * **Initiator sử dụng payload IDi để cho biết danh tính của mình:** Ví dụ như tên người dùng, địa chỉ IP, hay FQDN). Đây là cách nó thông báo "Tôi là ai" cho bên responder.

- * **Initiator bấm thông điệp:** Initiator sẽ thực hiện bấm theo công thức:

$$\text{Signature} = \text{HMAC}_{SK_{ai}} (\text{RealMessage1} \parallel \text{NonceR} \parallel \text{prf}(SK_{ai}, \text{IDi}'))$$

Trong đó:

Signature: Là dữ liệu bấm ra, ở đây không trình bày chữ ký số nhưng theo tài liệu chung về cách cài đặt của IKE thì cách gọi này vẫn được chấp nhận.

RealMessage1: Dữ liệu của thông điệp IKE_SA_INIT của Initiator (Initiator phải lưu lại thông điệp này) (được chuyển đổi thành mảng byte).

NonceR: Nonce của Responder, được chuyển đổi thành mảng byte.

prf(SK_{ai} , IDi'): Kết quả của hàm PRF sử dụng khóa SK_{ai} và dữ liệu danh tính của Initiator (IDi) sau khi loại bỏ phần header.

HMAC $_{SK_{ai}}$: Hàm HMAC với khóa SK_{ai} .

- * **Initiator mã hóa thông điệp:** Đóng gói Signature vào phần data của Payload Auth. Sau đó, Initiator sẽ mã hóa tất cả payload với thuật toán mã hóa bí mật được thỏa thuận từ trước với khóa SK_{ei} . Cho các ciphertext vào phần data của Payload Encrypting. Vậy Initiator sẽ gửi thông điệp IKE với tiêu đề và một payload duy nhất là Encrypting Payload.
- * **Responder giải mã thông điệp:** Responder nhận thông điệp, dùng khóa SK_{ei} được tính bên máy mình để giải mã, sau đó tách các payload ra. Lấy data từ Payload Auth (dữ liệu đã bấm MAC) và danh tính của Initiator trong data payload IDi.
- * **Responder xác minh MAC:** Responder sẽ thực hiện bấm tương tự cách làm của Initiator, rồi so sánh với MAC của Initiator. Nếu MAC khớp thì xác thực thành công, nếu không thì Responder sẽ ngắt kết nối.

- * **Responder băm thông điệp:** Responder sẽ thực hiện băm theo công thức:

$$\text{Signature} = \text{HMAC}_{SK_{ar}} (\text{RealMessage2} \parallel \text{NonceI} \parallel \text{prf}(SK_{ar}, \text{IDr}'))$$

Trong đó:

Signature: Là dữ liệu băm ra, ở đây không trình bày chữ ký số nhưng theo tài liệu chung về cách cài đặt của IKE thì cách gọi này vẫn được chấp nhận.

RealMessage2: Dữ liệu của thông điệp IKE_SA_INIT của Responder (Responder phải lưu lại thông điệp này) (được chuyển đổi thành mảng byte).

NonceI: Nonce của Initiator, được chuyển đổi thành mảng byte.

prf(SK_{ar} , IDr'): Kết quả của hàm PRF sử dụng khóa SK_{ar} và dữ liệu danh tính của Initiator (IDr) sau khi loại bỏ phần header.

HMAC $_{SK_{ar}}$: Hàm HMAC với khóa SK_{ar} .

- * **Responder khẳng định danh tính của mình thông qua payload IDr**
- * **Responder mã hóa thông điệp:** Gộp các payload lại và mã hóa tương tự như cách làm của Initiator, nhưng lần này là dùng khóa SK_{er}
- * **Initiator giải mã thông điệp:** Tương tự như cách làm của Responder, nhưng lần này là dùng khóa SK_{er}
- * **Initiator xác minh MAC:** Initiator sẽ thực hiện băm tương tự cách làm của Responder, rồi so sánh với MAC của Responder (lấy từ data của payload AUTH). Nếu MAC khớp thì xác thực thành công, nếu không thì Initiator sẽ ngắt kết nối.
- * Thiết lập IPsec SA để mã hóa lưu lượng dữ liệu.
- * Ngoài ra, 2 bên đều xử lý logic với các gói Tsi/Tsr để quyết định lưu lượng gói tin được gửi đi để ngăn chặn tấn công dựa trên việc giả mạo hay chèn lưu lượng sai phạm vi (đặc biệt là IP spoofing), vì chỉ những gói tin nằm trong phạm vi địa chỉ/giao thức/cổng đã thỏa thuận mới được mã hóa và truyền qua kênh IPsec.. Hai bên cũng bắt đầu thỏa thuận Child SA bằng 2 payload là SAi và SAR, giúp bổ sung thêm các thông số bảo mật chi tiết.

– Kết quả:

- * Hai bên tin tưởng nhau là thật và không bị giả mạo.
- * Các khóa mã hóa (SK_{ei}/SK_{er}) được dùng để thiết lập IPsec SA, chính thức bắt đầu được sử dụng để mã hóa luồng dữ liệu thực tế.

- Bước 2: Trao đổi CREATE_CHILD_SA

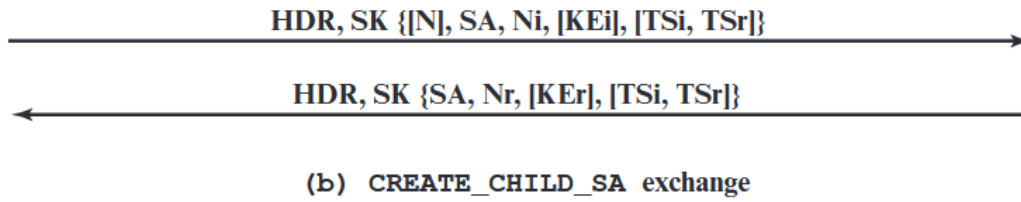


Figure 7: CREATE CHILD SA

- Mục đích: Tạo thêm các Child SA hoặc thay khóa cho các SA hiện tại..
- Quá trình:
 - * Initiator có thể đề xuất Responder thay khóa hoặc tạo khóa con (gửi payload SA và payload Nonce để đảm bảo tính mới).
 - * Cả hai bên đều phải gói các payload và mã hóa, đưa vào phần data của Payload Encrypting để gửi đi (như phần 1.2).
- Kết quả: Tạo thêm các IPsec SA mới nếu cần

Bước 3: Trao đổi INFORMATIONAL

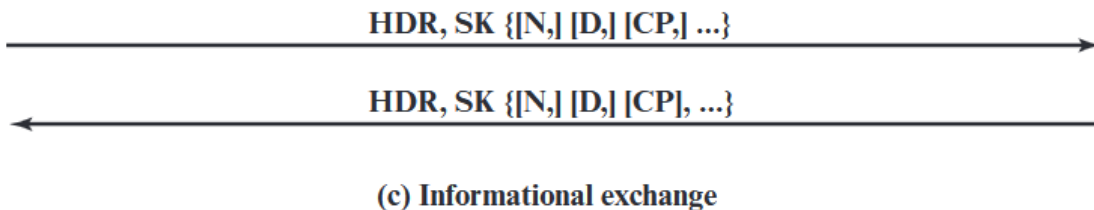


Figure 8: INFORMATIONAL

- Mục đích: Trao đổi các thông tin về trạng thái SA, như thông báo lỗi hoặc xóa SA.
- Quá trình:
 - * Initiator sẽ gửi gói tin được mã hóa bằng khóa SK_{e_i} sinh ra từ khóa mầm Skeyseed. Trong gói tin đó chứa các Payload: N (để thông báo sự kiện quan trọng), D (để xóa SA), CP (cấu hình lại các thông số trong SA).
 - * Responder sẽ gửi hồi đáp với gói tin mã bằng khóa SK_{e_r} .
- Kết quả: Quản lý các phiên giao tiếp và duy trì kết nối IKEv2

2.5 Bộ mã khuyến nghị cho giao thức IKE

2.5.1 Virtual Private Networks (RFC 4308)

- RFC 4308 định nghĩa hai bộ mật mã cho mạng riêng ảo (Virtual Private Networks - VPNs):
 - VPN-A: Sử dụng các thuật toán mã hóa và xác thực phổ biến ở thời điểm IKEv1 (2005).
 - VPN-B: Cung cấp bảo mật mạnh hơn, được thiết kế cho IKEv2.
- Ba loại thuật toán khóa bí mật được sử dụng:
 - Mã hóa (Encryption): Sử dụng CBC (Cipher Block Chaining)
 - * VPN-A: 3DES-CBC
 - * VPN-B: AES-CBC
 - Xác thực thông điệp (Message Authentication)
 - * VPN-A: HMAC-SHA1 (với đầu ra bị cắt bớt thành 96 bits)
 - * VPN-B: CMAC-AES (với đầu ra bị cắt bớt thành 96 bits)
 - Hàm giả ngẫu nhiên (Pseudorandom Function): (được tạo từ hàm MAC đã chọn, chẳng hạn như HMAC hoặc CMAC) IKEv2 tạo ra các bit giả ngẫu nhiên bằng cách sử dụng nhiều lần MAC được dùng để xác thực thông điệp.

2.5.2 NSA Suite B (RFC 6379)

- RFC 6379 định nghĩa các bộ mật mã tương thích với tiêu chuẩn bảo mật Suite B của NSA (Cơ quan An ninh Quốc gia Hoa Kỳ), hỗ trợ cả bảo mật cao và hiệu năng. Suite B được thiết kế để bảo vệ dữ liệu nhạy cảm và không phân loại.
- Các thuật toán trong Suite B dùng cho IKE:
 - Mã hóa: AES-CBC
 - Xác thực thông điệp: HMAC-SHA3
 - Hàm giả ngẫu nhiên: Giống như các bộ VPN, IKEv2 trong các bộ này tạo ra các bit giả ngẫu nhiên bằng cách sử dụng nhiều lần MAC được dùng để xác thực thông điệp.
- Trao đổi khóa cho cả 2 bộ mã hóa (RFC 4308 và RFC 6379) thì dùng nhóm Diffie-Hellman trên đường cong Elliptic để thiết lập khóa chung mà không cần chia sẻ trực tiếp.

3 Sản phẩm demo của nhóm (có link video demo)

- Link demo: <https://www.youtube.com/watch?v=-H6wyDsx6zo>

- Mục tiêu tổng thể của nhóm cho demo IKEv2 là pha 1 (SA INIT) thông qua lập trình Socket. Lý do nhóm chọn pha 1 bởi vì: Đây là pha quan trọng nhất trong giao thức IKE, tổng hợp tất cả các bước trao đổi khóa DH, sinh khóa mầm Skeyseed, sinh các khóa con để mã và chứng thực. Các quá trình mã hóa, xác thực cũng diễn ra ở pha này.

- Ở giai đoạn 3 Seminar, nhóm đã nghiên cứu và hoàn thành cài đặt bước 1.1, 1.2 của pha SA INIT:

- Nhóm đã thiết kế và trao đổi các gói tin KE_i , KE_r , Ni/Nr , Auth, ID_i , ID_r , ENC theo dạng gói tin nhị phân (Không phải là Text).
- Trao đổi khóa Diffie Hellman, số ngẫu nhiên của Responder-Initiator thành công.
- Từ đó, nhóm đã tính toán được khóa bí mật chung từ khóa Diffie Hellman vừa trao đổi, và tính khóa được Skeyseed.
- Từ khóa mầm Skeyseed, nhóm đã cài đặt để sinh ra một xích khóa, và phân rã thành các khóa con. Các khóa con sẽ dùng cho việc mã hóa và chứng thực.
- Initiator sẽ gửi gói tin bao gồm AUTH và ID_i được mã hóa bằng khóa SK_{e_i} sinh ra từ khóa mầm Skeyseed và gói trong gói tin Encrypting.
- Responder sẽ giải mã gói tin Encrypting, lấy dữ liệu băm từ AUTH và dữ liệu danh tính ID_i , tiến hành băm và kiểm tra MAC. Nếu hợp lệ thì in ra xác thực thành công, nếu không thì in ra xác thực thất bại.
- Responder sẽ gửi gói tin bao gồm AUTH và ID_r được mã hóa bằng khóa SK_{e_r} sinh ra từ khóa mầm Skeyseed và gói trong gói tin Encrypting.
- Tương tự, Initiator sẽ giải mã gói tin Encrypting, lấy dữ liệu băm từ AUTH và dữ liệu danh tính ID_r , tiến hành băm và kiểm tra MAC. Nếu hợp lệ thì in ra xác thực thành công, nếu không thì in ra xác thực thất bại. Kết thúc 4 bước bắt tay của pha SA INIT.
- Về gói tin SA Payload: Nhóm đã có khảo sát và báo cáo, nhưng không cài đặt vì nhóm chỉ cài duy nhất bộ mã khuyến nghị NSA Suite B (RFC 6379) (gồm các thuật toán: AES - CBC 128 bit key cho mã hóa, HMAC-SHA-256 cho hàm sinh số giả ngẫu nhiên, HMAC-SHA-256-128 cho xác thực, ECP 256 bit cho tính toán khóa Diffie Hellman) cho bên Responder, vì vậy cài gói tin SA Payload để Initiator đề xuất nhiều bộ mã là không cần thiết.

- Môi trường lập trình: IDE Visual Studio 2022, ngôn ngữ lập trình C/C++ 20, thư viện mã hóa đang xài Crypto++ (dùng cho các thuật toán mã hóa và xác thực)

4 Tham khảo

- Stallings, W. (2017). Cryptography and Network Security: Principles and Practice (7th Edition). Pearson.
- RFC 7296 – Internet Key Exchange Protocol Version 2 (IKEv2): <https://datatracker.ietf.org/doc/html/rfc7296>
- Slide bài giảng Mã hóa ứng dụng - thầy Trần Minh Triết - thầy Trương Toàn Thịnh.